

Executive Summary — STIKOM Bali Pentest 2026

Target: Sistem Informasi Akademik & Pembayaran ITB STIKOM Bali **Tanggal:** 22 Juni 2026 **Metodologi:** Black-box, OWASP Testing Guide **Reporter:** Afiq Andico Pangimpian (mahasiswa ITB STIKOM Bali)

Apa yang Kami Uji

Infrastruktur web ITB STIKOM Bali di domain *.stikom-bali.ac.id : - **Domain utama** (SION): sion.stikom-bali.ac.id - **Sistem pembayaran:** pembayaran.stikom-bali.ac.id - **Subdomain lainnya:** API, absensi, alumni, dll

Temuan Utama

5 kerentanan ditemukan, dengan 1 kontrol keamanan yang sudah tepat.

● CRITICAL — Origin IP Exposure & WAF Bypass

Domain utama dilindungi Cloudflare WAF, tapi subdomain pembayaran.stikom-bali.ac.id **tidak** — mengekspos IP asli server (103.148.xxx.xxx) yang bisa diserang langsung tanpa melalui WAF.

Dampak: Penyerang bisa meluncurkan DDoS langsung atau eksploitasi kerentanan lain tanpa filter.

● HIGH — Tidak Ada Rate Limiting pada Login

Endpoint autentikasi (/admin/proses_login) **tidak membatasi jumlah percobaan login**. 10 percobaan gagal berturut-turut tetap diterima server tanpa blokir.

Dampak: Brute-force attack terhadap akun admin bisa dilakukan tanpa hambatan.

● HIGH — Debug Mode Aktif di Produksi

Server mengembalikan **stack trace lengkap** saat terjadi error API, membocorkan path absolut server (`/var/www/pembayaran...`) dan informasi framework.

Dampak: Penyerang mengetahui struktur internal server, memudahkan eksploitasi lanjutan.

● MEDIUM — Pesan Error Terlalu Detail

API mengembalikan pesan validasi eksplisit (mis: "These credentials do not match our records"), membocorkan field mana yang salah.

Dampak: Membantu penyerang melakukan reverse engineering API.

● MEDIUM — Konfigurasi Web Server Kurang Ketat

Folder internal framework (`/application`) bisa diakses langsung dari browser (meskipun isinya dilindungi oleh framework).

Dampak: Indikasi kurangnya hardening web server.

● AMAN — User Enumeration di Forgot Password

Endpoint `/api/forgot-password` mengembalikan respons identik untuk email yang terdaftar maupun tidak. **Praktik keamanan yang baik — tidak ada kerentanan.**

Dampak Bisnis (jika tidak ditangani)

- **Pengambilalihan akun admin** sistem pembayaran → akses data mahasiswa & transaksi
 - **Kebocoran data pribadi** mahasiswa (NIM, nama, dll)
 - **Serangan DDoS langsung** ke server origin (skip WAF)
 - **Kerusakan reputasi** institusi
 - **Potensi kerugian finansial** jika data transaksi dimanipulasi
-

Rekomendasi Prioritas (3 Langkah Pertama)

1. **Segera** — Konfigurasi semua subdomain melalui Cloudflare WAF (khususnya pembayaran)
2. **Minggu ini** — Implementasikan rate limiting + CAPTCHA di endpoint login
3. **Minggu ini** — Matikan debug mode di server produksi

Detail lengkap: lihat [remediation.md](#) dan [findings/](#).

Status Disclosure

-  Laporan dikirim ke IT STIKOM Bali
-  Menunggu tindakan perbaikan
-  Public disclosure: 90 hari setelah pengiriman (jika tidak ada response)

Detail timeline: [disclosure-timeline.md](#).

Disclaimer: Pengujian dilakukan secara pasif dan non-destruktif sesuai etika responsible disclosure. Tidak ada data yang dieksploitasi, diambil, atau dimanipulasi. Tujuan murni edukasi dan peningkatan keamanan institusi.